

DATA SHARING GOVERNANCE FRAMEWORK

Third-Party Personal Data Sharing Governance under India's **DPDP Act, 2023**



RISK-BASED VENDOR ASSESSMENT

Evaluate, classify and manage third-party risks



CONTRACTUAL SAFEGUARDS

DPDP-aligned DPA and data sharing controls



ONGOING MONITORING & ASSURANCE

Continuous oversight, KPIs and compliance tracking



OFFBOARDING & DATA DELETION

Secure exit and verified deletion of personal data



Building Trust.
Protecting People.
Governed by **Design**.



PRIVACY | ACCOUNTABILITY | TRANSPARENCY | SECURITY

A compliance-readiness framework for responsible and lawful data sharing.



Prepared as a Portfolio Project



July 2026

Fictional Organisation

For Demonstration Purposes Only



DATA SHARING GOVERNANCE FRAMEWORK

Third-Party Personal Data Sharing Governance under India's DPDP Act, 2023

Table of Contents

1. Executive Summary	4
2. Organisation and Data Sharing Scenario	6
3. DPDP Act Legal and Governance Mapping	10
4. Data Sharing Governance Principles	16
5. End-to-End Third-Party Data Sharing Lifecycle	18
6. Data Sharing Request Form Template	20
7. Third-Party Privacy Risk Assessment Methodology	22
8. Third-Party Risk Assessment Template Sample Completed Assessment	26
9. Vendor Risk Classification Matrix	29
10. Data Processing and Data Sharing Contract Template (Data Processing Addendum)	30
11. Data Sharing Approval Matrix / RACI	34
12. Third-Party Breach Escalation Process	36
13. Vendor Offboarding and Data Deletion Checklist	39
14. Ongoing Vendor Monitoring Framework	40
15. Governance KPIs and KRIs	41
16. Sample Data Sharing Governance Register	44
17. Key Findings and Governance Recommendations	45
18. Portfolio Case Study Summary	46

IMPORTANT NOTICE — PORTFOLIO / DEMONSTRATION DOCUMENT

This document is a **fictional portfolio project** created to demonstrate privacy governance and DPDP Act, 2023 compliance-design skills for career purposes (Data Privacy Analyst / Privacy Operations / Privacy Governance / DPO interview preparation). The organisation, vendors, individuals, financial figures, and completed assessments described here are **entirely fictional** and are not based on any real company. This document is **not legal advice**. Any organisation implementing a similar framework should have it reviewed by qualified legal counsel.

Legal-currency note: The Digital Personal Data Protection Act, 2023 (DPDP Act) received Presidential assent on 11 August 2023. The Digital Personal Data Protection Rules, 2025, were notified on 13 November 2025, and the Act and Rules are being brought into force in a phased manner, with most substantive compliance obligations (Chapter II and III provisions, the Data Protection Board's enforcement powers, and the penalty schedule) becoming fully operative by **13 May 2027**. This framework is written as a **compliance-readiness framework** — i.e., the practical governance program an organisation should already be operating so that it is fully prepared ahead of, and remains compliant after, the relevant provisions come into force. Where a provision is not yet in force, this is noted rather than presented as a current enforceable obligation.

1 . Executive Summary

1.1 Purpose of the Framework

This Data Sharing Governance Framework (“the Framework”) establishes the end-to-end controls that **Vintara HR Cloud Private Limited** (“Vintara” or “the Organisation,” a fictional Indian HR-technology/SaaS company) applies whenever it shares personal data with a third party. It converts the obligations of the Digital Personal Data Protection Act, 2023 (“DPDP Act”) — and associated governance best practice — into an operational program covering vendor screening, risk assessment, contracting, onboarding, monitoring, breach escalation, and offboarding.

The Framework treats third-party data sharing as a **lifecycle risk**, not a one-time contractual event. Every vendor relationship that touches personal data is assessed, classified, contracted, monitored, and eventually wound down under a consistent, auditable process, regardless of which department initiates the relationship.

1.2 Why Third-Party Data Sharing Is a Privacy Risk

Vintara does not process personal data in isolation. As an HR-technology provider, it necessarily shares personal data of job candidates, client employees, its own staff, and client administrators with cloud hosting providers, payroll processors, background-verification vendors, communication platforms, analytics tools, and customer-support systems. Each of these relationships introduces risk because:

- Personal data leaves Vintara’s direct operational control once shared, but **legal responsibility does not leave with it**.
- Vendors may retain, secondarily use, or sub-process data in ways the Organisation did not intend or authorise.
- Vendors may be hosted outside India, raising cross-border processing considerations.
- A vendor’s security failure becomes Vintara’s personal data breach for regulatory and contractual purposes.
- Vendor relationships end, but data does not automatically disappear — deletion must be verified, not assumed.

1.3 Why Third-Party Governance Matters under the DPDP Act

Under the DPDP Act, Vintara is a **Data Fiduciary**, the entity that determines the purpose and means of processing personal data. The Act’s Data Processor model places the primary compliance burden on the Data Fiduciary: a Data Fiduciary may only engage a Data Processor under a valid contract, remains responsible for the processing carried out on its behalf, and must ensure reasonable security safeguards across the entire processing chain, including processing done by processors. This means Vintara cannot outsource

its accountability; it can only outsource the processing activity itself. Strong third-party governance is therefore not optional operational hygiene; it is the mechanism through which Vintara actually discharges its statutory obligations.

1.4 Main Governance Controls Introduced

Control Area	What It Does
Data Sharing Request Form	Forces a documented, purpose-justified decision before any new data sharing begins
Third-Party Privacy Risk Assessment	Scores every vendor relationship against defined risk factors before onboarding
Vendor Risk Classification Matrix	Sets proportionate contract, review, and monitoring requirements by risk tier
Data Processing Addendum (DPA) Template	Embeds DPDP-relevant contractual controls into every vendor contract
RACI / Approval Matrix	Removes ambiguity about who approves, reviews, and is accountable at each stage
Ongoing Monitoring Framework	Converts one-time due diligence into continuous assurance
Breach Escalation Workflow	Gives a pre-agreed path from vendor incident detection to regulatory/contractual response
Offboarding & Deletion Checklist	Ensures data does not survive the vendor relationship without justification
Governance KPIs/KRIs	Makes the health of the program visible and measurable to leadership

2 . Organisation and Data Sharing Scenario

2.1 Fictional Organisation Profile

Vintara HR Cloud Private Limited (fictional) is a mid-sized, India-headquartered HR-technology SaaS company (approx. 480 employees) that sells a cloud-based Human Capital Management (HCM) platform to approximately 210 client companies across India, the UAE, and Southeast Asia. The platform covers recruitment, employee records, payroll processing, performance management, and background verification coordination.

Assumptions used throughout this project (stated explicitly per project instructions):

1. Vintara is assumed to be a **Data Fiduciary** under the DPDP Act for the personal data it determines the purpose and means of processing (its own employees, job candidates it directly recruits for, and the overall platform architecture).
2. For client-employee personal data processed *on behalf of* client companies (Vintara's own HCM customers), Vintara acts as a **Data Processor** to those client companies, who are themselves Data Fiduciaries. This project focuses on Vintara's downstream sharing with **its own sub-processors/vendors**, i.e., Vintara acting in a Data-Fiduciary-like risk-owner capacity over its supply chain, consistent with how the Act requires Data Fiduciaries (and, by contractual flow-down, processors) to control further sharing.
3. Vintara is **not assumed** to be a Significant Data Fiduciary (SDF). SDF status is a **Central Government notification/designation** under Section 10 of the DPDP Act based on factors such as volume and sensitivity of personal data processed, risk to Data Principal rights, and other prescribed factors — it is not self-declared or automatically triggered by company size. Nothing in this fictional scenario assumes such notification has occurred. Where SDF-only obligations are discussed, they are explicitly labelled as **not applicable to Vintara under current assumptions**.
4. Vintara processes personal data of Indian Data Principals predominantly, with some client operations in the UAE and Southeast Asia (relevant to cross-border processing discussion in Section 3.7).
5. All vendor names, individuals, financial figures, dates of assessment, and incident scenarios used in this project are **fictional** and created solely to illustrate the governance methodology.

2.2 Data Principals Whose Data Vintara Shares

- **Client employees** — personal data processed via the HCM platform on behalf of client companies (payroll, attendance, performance, leave, benefits).

- **Job candidates** — personal data collected during recruitment and background-verification workflows, for Vintara's own hiring and on behalf of client hiring processes.
- **Vintara's own employees** — HR, payroll, IT, and benefits data processed internally.
- **Client HR administrators/business users** — account, authentication, and usage data for individuals who log in to the platform on behalf of client organisations.

2.3 Third-Party / Vendor Relationships

	Vendor Category	Business Purpose	Personal Data Shared	Data Principal Categories	Processing Activity	Vendor Role	Hosting/ Processing Location	Key Risk Considerations
1	Cloud Hosting Provider (“CloudNova Infra,” fictional)	Hosts Vintara’s production HCM application and databases	Full HCM dataset: names, contact details, compensation, government ID numbers, bank details	Client employees, candidates, Vintara employees	Storage, compute, backups	Data Processor (sub-processor of Vintara)	Primary: Mumbai (AWS ap-south-1 equivalent); DR: Singapore	Broadest data footprint; cross-border DR replication; encryption key management; sub-sub-processor (hardware/network) layers
2	Payroll & Benefits Processor (“PayAssure Solutions,” fictional)	Runs monthly payroll, statutory filings, benefits administration for client employees	Bank account numbers, PAN, salary structure, tax declarations	Client employees	Computation, statutory filing, disbursement instructions	Data Processor	India (on-premise + Mumbai cloud)	Highly sensitive financial data; direct disbursement access; statutory retention obligations (tax law) may exceed DPDP erasure triggers
3	Background Verification Vendor (“VerifiTrust Screening,” fictional)	Conducts employment, education, criminal-record, and address verification for candidates	Full name, DOB, ID document numbers, address history, prior employment/ education records, court-record search results	Job candidates	Verification checks, third-party record lookups (e.g., court databases, universities)	Data Processor (with its own sub-processors, e.g., field verification agents)	India, multiple regional field offices	Sensitive/high-risk data category in practice; extensive further sub-processing to field agents and record sources; potential inaccurate/ adverse data affecting candidates

	Vendor Category	Business Purpose	Personal Data Shared	Data Principal Categories	Processing Activity	Vendor Role	Hosting/ Processing Location	Key Risk Considerations
4	Email & Communication Platform (“MailBridge Cloud,” fictional, global SaaS)	Corporate email, calendaring, and internal messaging	Employee names, email content/ metadata, calendar details	Vintara employees, incidentally client contacts in correspondence	Message transmission, storage	Data Processor	Multi-region global (including outside India)	Global multi-tenant SaaS; standard (non-negotiable) vendor terms; cross-border storage; broad incidental exposure of correspondence
5	Product/Usage Analytics Provider (“MetricPulse Analytics,” fictional)	Tracks in-app usage patterns to improve the HCM platform	Pseudonymised user IDs, IP address, device/browser data, feature-usage events	Client HR administrators, client employees (end users)	Behavioural/ usage analytics, aggregated reporting	Data Processor	US and EU regions (global SaaS)	Cross-border transfer; risk of re-identification from pseudonymised IDs; vendor’s own downstream analytics sub-processors
6	Customer Support / Helpdesk Tool (“SupportDeck,” fictional)	Manages client support tickets and internal IT helpdesk tickets	Names, email, screenshots/ attachments that may contain personal data, ticket content	Client HR administrators, Vintara employees	Ticket logging, storage, agent-assisted resolution	Data Processor	India + US (hybrid hosting)	Attachments/ screenshots often contain unfiltered personal data beyond the minimum needed; support agents have broad read access
7	E-Signature / Offer-Letter Platform (“SignRight,” fictional)	Digital signing of offer letters, employment contracts, NDAs	Full name, address, signature, ID proof uploads	Candidates, client employees	Document generation, e-signature capture, storage	Data Processor	India	Identity-document uploads are high-value target data; long document retention

	Vendor Category	Business Purpose	Personal Data Shared	Data Principal Categories	Processing Activity	Vendor Role	Hosting/ Processing Location	Key Risk Considerations
8	AI Resume-Screening Add-on (“SkillMatch AI,” fictional)	Automated resume parsing and candidate-fit scoring	Resume content, education, work history, inferred skill/fit scores	Job candidates	Automated/algorithmic processing to generate candidate scores	Data Processor	India (model hosted on Vintara’s cloud tenant, vendor-managed)	Automated decision-support risk; explainability and fairness considerations; new AI/automated-processing risk factor

3 . DPDP Act Legal and Governance Mapping

3.1 Approach to This Section

This section maps DPDP Act provisions to third-party data-sharing governance controls. Section numbers below are drawn from the Digital Personal Data Protection Act, 2023 (Act No. 22 of 2023) as enacted, read together with the Digital Personal Data Protection Rules, 2025 (notified 13 November 2025), where relevant. Where a control in this Framework is **not** an express statutory requirement, it is labelled accordingly. GDPR concepts (e.g., “joint controllers,” “Article 28 processor clauses,” “SCCs,” “DPIA-for-every-vendor”) are **not** treated as DPDP Act requirements; they are noted only for contrast where useful, and any control based on such practice is separately labelled as governance best practice.

3.2 Legal Mapping Table

DPDP Act Provision	Legal Requirement (Summary)	Relevance to Third-Party Data Sharing	Governance Control in This Framework
Section 2(k) — definition of “Data Processor”	Defines a Data Processor as any person who processes personal data on behalf of a Data Fiduciary	Establishes that Vintara’s vendors who process personal data on Vintara’s instructions are Data Processors, not independent Data Fiduciaries, for that processing	Vendor role field in the Data Sharing Request Form and Register (Sections 6, 16) distinguishes Processor vs. independent-Fiduciary vendors
Section 4 & Section 6 — grounds for processing / consent	Personal data may generally be processed only on the basis of consent that is free, specific, informed, unconditional and unambiguous, or under Section 7 legitimate uses	Any new sharing must be traceable to a valid processing ground already established with the Data Principal — sharing cannot create a new, un-consented purpose	Purpose-alignment principle (Section 4.2) and “Business Purpose” / “Description of Processing” fields on the Request Form (Section 6)
Section 7 — certain legitimate uses	Permits processing without consent in defined circumstances (e.g., voluntarily provided data for a stated purpose, employment purposes, legal compliance, medical emergencies, public order)	Relevant where employee data is shared with payroll/benefits vendors for employment-related purposes without seeking fresh consent for each vendor	Legal-basis check embedded in the Privacy Screening stage of the lifecycle (Section 5)
Section 8(2) — engagement of Data Processors only under a valid contract	A Data Fiduciary may engage a Data Processor to process personal data on its behalf only under a valid contract	This is the central statutory hook for third-party contracting	Mandatory Data Processing Addendum (Section 10) required before any live data sharing; “Existing Contract Status” gate on the Request Form
Section 8(1) — accuracy	Data Fiduciary must ensure completeness, accuracy, and consistency of personal data used to make decisions or disclosed to another Data Fiduciary	Relevant where inaccurate data (e.g., a background-check false positive) is shared onward or used in decisions	Accuracy/remediation checkpoints in the Third-Party Risk Assessment (Section 7) and vendor monitoring (Section 14)

DPDP Act Provision	Legal Requirement (Summary)	Relevance to Third-Party Data Sharing	Governance Control in This Framework
Section 8(5) — reasonable security safeguards	Data Fiduciary must protect personal data in its possession or control, including data processed on its behalf by a Data Processor , through reasonable security safeguards	The Fiduciary's security obligation extends through the vendor; Vintara cannot rely on a vendor's own assurances without verification	Security-safeguard review criteria in the Risk Assessment Questionnaire (Section 7); DPA security clause (Section 10)
Section 8(6) — personal data breach intimation	On a personal data breach, the Data Fiduciary must intimate the Data Protection Board of India and each affected Data Principal, in the prescribed form and manner	This obligation is triggered even when the breach originates at a vendor; Vintara needs contractual visibility to be able to comply	Breach Escalation Workflow (Section 12); DPA breach-notification clause
Section 8(7) — erasure of personal data, including by the Data Processor	Data Fiduciary must erase personal data on consent withdrawal / purpose cessation, unless retention is required by other law, and must cause its Data Processor to erase any personal data made available to it	Directly supports the offboarding/deletion obligations toward vendors	Vendor Offboarding & Data Deletion Checklist and Deletion Confirmation Certificate (Section 13); Retention field on Request Form
Section 8(8) — deemed cessation of specified purpose	Clarifies when a purpose is deemed no longer served (e.g., Data Principal does not re-engage / exercise rights within a prescribed period)	Informs retention-period design for vendor-held data tied to a specific purpose (e.g., a closed candidate application)	Retention-period field in Request Form and Register; retention review in Ongoing Monitoring Framework

DPDP Act Provision	Legal Requirement (Summary)	Relevance to Third-Party Data Sharing	Governance Control in This Framework
Section 9	Additional obligations regarding processing of children's personal data and persons with disabilities having a lawful guardian	Not a primary focus of this B2B/employment-context project, but relevant if candidate data includes minors (rare) or guardian-managed data	Flagged as an exception-handling note in the Risk Assessment questionnaire rather than a standing control, given limited applicability
Section 10 — Significant Data Fiduciary (SDF)	Certain Data Fiduciaries may be notified by the Central Government as SDFs and made subject to enhanced obligations (e.g., DPO, independent data auditor, DPIA)	Not applicable under this project's assumptions — Vintara has not been notified as an SDF	Explicitly excluded from mandatory controls in this Framework; noted as a "future-state" consideration only if Vintara is later designated
Section 16	Central Government may restrict transfer of personal data to specified countries/territories by notification (a "negative list" model, rather than an approved-country/SCC model)	Relevant to hosting-location and cross-border-vendor decisions (e.g., MailBridge Cloud, MetricPulse Analytics)	Hosting/Processing Location field on Request Form and Register; cross-border flag in Risk Assessment
Section 17	Exemptions from specified obligations in defined circumstances (e.g., enforcement of legal rights, certain processing by courts/tribunals, research/archival purposes as may be notified)	Narrow relevance; noted so the Framework does not overstate universal applicability of every obligation in every circumstance	Not built into a standing control; retained as a legal-review consideration for Legal/Privacy during contract review

DPDP Act Provision	Legal Requirement (Summary)	Relevance to Third-Party Data Sharing	Governance Control in This Framework
Section 33 and Schedule (Penalties)	Financial penalties (up to ₹250 crore per contravention category under the Schedule) may be imposed by the Data Protection Board for specified contraventions, including failure to implement reasonable security safeguards and failure to notify a breach	Explains the business case for rigorous vendor governance	Referenced in the Executive Summary and KPI/KRI escalation rationale (Section 15) as the regulatory-risk driver, not cited as if currently enforced against Vintara
DPDP Rules, 2025 — Rule 6	Prescribes categories of reasonable security safeguards a Data Fiduciary (and, by contractual flow-down, its Processors) should implement (e.g., encryption, access control, monitoring, backups)	Gives operational content to the Section 8(5) obligation	Security-safeguard checklist embedded in Risk Assessment questionnaire and DPA Schedule (Sections 7, 10)
DPDP Rules, 2025 — Rule 7	Prescribes the form, manner, and expected diligence around intimation of a personal data breach to the Board and Data Principals	Operationalises Section 8(6)	Breach Escalation Workflow decision points (Section 12)
DPDP Rules, 2025 — Rule 8	Prescribes erasure timelines/notice mechanics for certain classes of Data Fiduciary (e.g., a defined notice period to the Data Principal before erasure for inactivity-based cessation)	Informs how Vintara designs vendor-side retention/deletion triggers	Retention & deletion fields (Sections 6, 13, 16)

Note on timelines: Some secondary sources describe a specific hour-based clock for breach notification to the Board (commonly discussed as being aligned to Rule 7’s mechanics). This Framework does **not** assert a specific statutory number of hours as a fixed

universal deadline, because the precise mechanics depend on the prescribed form/manner under the Rules and any subsequent Board guidance; Section 12 treats the exact notification window as a matter to be confirmed against the then-current Rules/Board directions at the time of an actual incident, and separately fixes a **contractual** (not statutory) vendor-to-Vintara notification timeline.

3.3 Governance Best Practices Layered on Top of the Statute

The following controls used in this Framework are **Governance Best Practice – Not an Express Statutory Requirement**:

- A four-tier (Low/Moderate/High/Critical) vendor risk-scoring model — the DPDP Act does not prescribe any specific risk-scoring methodology.
 - Fixed frequencies for reassessment (e.g., “annual” for high-risk vendors) — the Act does not mandate specific reassessment intervals for ordinary Data Fiduciaries.
 - A mandatory Data Sharing Request Form and RACI structure — internal governance process, not a statutory template.
 - Audit rights and evidence-of-deletion certificates in contracts — sound contractual risk allocation, not an express statutory clause requirement.
 - Treating background-verification and financial data as internally “high-risk” categories for scoring purposes — the DPDP Act does not create a GDPR-style “special category” of sensitive personal data; this is an internal risk-management classification only.
 - KPI/KRI metrics and monitoring calendars — operational management practice, not statutory.
-

4 . Data Sharing Governance Principles

Principle	What It Means	Why It Matters	How Vintara Operationalises It
Lawful Purpose	Every share must map to a valid processing ground already established for that data (consent or a Section 7 legitimate use)	Prevents “shadow” secondary uses that the Data Principal never authorised	Legal-basis field mandatory on the Data Sharing Request Form; rejected if blank
Purpose Alignment	The vendor’s use of the data must not exceed the original purpose for which it was collected	Vendors are often tempted to repurpose data (e.g., for their own product improvement)	Purpose-limitation clause in the DPA; purpose field cross-checked against the original notice given to the Data Principal
Data Minimisation	Only the data actually necessary for the vendor’s function is shared	Reduces breach impact and vendor over-collection	Business owner must justify each data field on the Request Form; Privacy reviews and can reject over-broad fields
Need-to-Share Assessment	A documented test of whether sharing is necessary at all, before assessing risk	Avoids treating “the business wants it” as automatic justification	Mandatory “Business Justification” narrative field, reviewed at the Privacy Screening stage
Vendor Due Diligence	Structured evaluation of a vendor’s privacy/security posture before onboarding	Prevents onboarding vendors with weak controls	Third-Party Privacy Risk Assessment (Section 7)
Contractual Controls	Binding, written obligations translate expectations into enforceable terms	Verbal assurances are not defensible in an audit or Board inquiry	Mandatory DPA before data flows (Section 10)

Principle	What It Means	Why It Matters	How Vintara Operationalises It
Security Safeguards	Technical and organisational measures appropriate to the risk of the data shared	Directly supports the Section 8(5) obligation	Security criteria embedded in risk scoring and DPA schedule
Access Limitation	Only the people/systems that need access to shared data get it, on a least-privilege basis	Limits blast radius of insider or credential-based incidents	Access-control review item in Risk Assessment; access-revocation step in Offboarding checklist
Retention and Deletion	Data is kept only as long as necessary and is verifiably deleted afterward	Directly supports Section 8(7) erasure obligations	Retention field on Request Form/Register; Deletion Confirmation Certificate (Section 13)
Breach Escalation	A pre-agreed path exists for vendor-originated incidents to reach Vintara's own breach response	Enables Vintara to meet its own Section 8(6) obligations despite not controlling the vendor's systems	Breach Escalation Workflow (Section 12)
Ongoing Monitoring	Due diligence does not end at contract signature	Vendor risk profiles change (sub-processors, incidents, ownership, technology)	Risk-based Monitoring Framework and Calendar (Section 14)
Accountability and Documentation	Every decision, approval, and control is documented and traceable	Demonstrates compliance to regulators, auditors, and leadership; core to the Fiduciary's non-delegable responsibility	Governance Register (Section 16), RACI (Section 11), retained assessment/approval records

5 . End-to-End Third-Party Data Sharing Lifecycle

Stage	Objective	Key Activities	Responsible Stakeholder	Required Documentation	Approval Requirement	Escalation Trigger
1. Business Request	Capture the business need for sharing data with a third party	Business team completes Data Sharing Request Form	Business Owner	Data Sharing Request Form	N/A (initiation)	Missing/incomplete purpose justification
2. Data Sharing Identification	Confirm what data, whose data, and why	Business Owner and Privacy jointly identify data elements, Data Principal categories	Business Owner + Privacy/DPO	Completed Request Form (data fields)	Privacy sign-off to proceed to screening	Sensitive/high-volume data identified
3. Privacy Screening	Check legal basis, purpose alignment, minimisation	Privacy reviews legal basis and necessity	Privacy/DPO	Screening notes	Privacy approval to proceed	No valid legal basis identified
4. Third-Party Risk Assessment	Score the vendor's privacy/security risk	Vendor questionnaire, evidence review, scoring	Privacy/DPO with Information Security	Completed Risk Assessment Template	N/A (assessment output feeds classification)	Any "Critical" individual risk-factor score
5. Risk Classification	Assign vendor to Low/Moderate/High/Critical tier	Apply scoring methodology (Section 7)	Privacy/DPO	Risk Classification record	N/A	Score at Critical threshold
6. Privacy / Security Review	Deep-dive review proportionate to risk tier	Security architecture review; privacy control review	Information Security + Privacy/DPO	Review report, remediation list	Joint Security + Privacy sign-off	Unremediated Critical/High gaps

Stage	Objective	Key Activities	Responsible Stakeholder	Required Documentation	Approval Requirement	Escalation Trigger
7. Contract Review	Ensure DPA contains required clauses	Legal reviews/ negotiates DPA against standard template	Legal	Reviewed/ executed DPA	Legal sign-off	Vendor refuses mandatory clauses
8. Approval	Formal go/no-go decision per Approval Matrix	Approval routed per risk tier (Section 11)	Approval Authority per tier (Sec. 9 matrix)	Approval record	Yes — per RACI/ Approval Matrix	High/Critical vendor lacking Senior Management sign-off
9. Vendor Onboarding	Operationalise access and data flow	Provision access, configure data feeds, brief vendor on obligations	IT + Vendor Management	Onboarding checklist	IT/Security confirmation of controls live	Access provisioned before contract execution
10. Ongoing Monitoring	Confirm continued compliance over the relationship	Reassessments, certification checks, breach monitoring	Privacy/DPO + Vendor Management	Monitoring records (Section 14)	N/A (periodic)	Overdue reassessment; adverse news/ certification lapse
11. Incident Management	Respond to vendor-originated personal data breach	Execute Breach Escalation Workflow (Section 12)	Privacy/DPO + Information Security	Incident record	Senior Management for Board/Data Principal notification	Any confirmed personal data breach
12. Contract Termination	Formally end the vendor relationship	Termination notice, transition planning	Vendor Management + Legal	Termination notice, transition plan	Business Owner + Legal	Termination for cause (breach/ non-compliance)

Stage	Objective	Key Activities	Responsible Stakeholder	Required Documentation	Approval Requirement	Escalation Trigger
13. Data Return / Deletion Verification	Confirm no residual personal data remains with the vendor	Execute Offboarding Checklist; obtain Deletion Certificate	Privacy/DPO + IT	Deletion Confirmation Certificate	Privacy/DPO final sign-off	Vendor unable/unwilling to certify deletion

6 . Data Sharing Request Form Template

VINTARA HR CLOUD PRIVATE LIMITED — DATA SHARING REQUEST FORM *(fictional template)*

Field	Entry
Request ID	DSR-2026-0XX
Requesting Department	
Business Owner (Name, Title, Email)	
Third-Party Name	
Business Purpose of Sharing	
Description of Processing Activity	
Categories of Data Principals Involved	
Types of Personal Data to Be Shared (list fields)	

Field	Entry
Sensitive / High-Risk Data Indicators (internal risk classification — <i>the DPDP Act does not define a statutory “special category” of personal data; this flag is an internal risk-management indicator only</i>)	☐ Financial/bank data ☐ Government ID numbers ☐ Background-check/criminal-record data ☐ Health data ☐ None identified
Approximate Data Volume	
Frequency of Sharing	☐ One-time ☐ Batch (specify) ☐ Real-time/continuous
Transfer Method (API, SFTP, manual upload, etc.)	
Hosting Location of Vendor Systems	
Processing Location(s)	
Sub-Processors Used by Vendor (if known)	
Proposed Retention Period	
Deletion Process at End of Purpose/Contract	
Existing Contract / DPA Status	☐ None ☐ Standard MSA only (no DPDP clauses) ☐ DPA in place
Security Review Status	☐ Not started ☐ In progress ☐ Complete
Privacy Review Status	☐ Not started ☐ In progress ☐ Complete
Declaration	“I confirm that this data-sharing request is necessary for the stated business purpose, that data has been minimised to what is necessary, and that I will cooperate with Privacy, Security, and Legal review requirements.”
Business Owner Signature / Date	
Privacy/DPO Review & Decision	☐ Approved to proceed ☐ Rejected ☐ Approved with conditions: ____
Approving Authority (per Approval Matrix)	

7 . Third-Party Privacy Risk Assessment Methodology

7.1 Nature of This Methodology

This is a governance risk-scoring methodology designed for this project — it is not a statutory DPDP Act scoring system. The DPDP Act does not prescribe a vendor risk-scoring framework; Vintara has designed this model as an internal governance tool to make risk-based decisions consistent and defensible.

7.2 Risk Factors and Scoring Criteria (1 = Low, 2 = Moderate, 3 = High, 4 = Critical)

#	Risk Factor	Score 1 (Low)	Score 2 (Moderate)	Score 3 (High)	Score 4 (Critical)
1	Nature of personal data	Basic contact data only	Contact + employment data	Financial/ID data	Background-check, biometric-adjacent, or combined identity + financial + behavioural data
2	Volume of data	<1,000 records	1,000–10,000	10,000–100,000	>100,000 records
3	Scale of Data Principals affected	Single department	Single client	Multiple clients	All clients/entire platform
4	Processing purpose sensitivity	Administrative/logistics	Operational/ service delivery	Decision-influencing (e.g., screening)	Decision-determining with limited human review
5	Data accessibility (access breadth at vendor)	Single named contact	Small defined team	Broad team access	Unrestricted/unclear access model
6	Hosting/ processing geography	India only	India + one known jurisdiction	Multiple jurisdictions, some undisclosed	Undisclosed/uncontrolled sub-hosting
7	Use of sub-processors	None	Disclosed, approved	Disclosed, not pre-approved	Undisclosed sub-processors
8	Security maturity (certifications, controls)	ISO 27001/SOC2 + strong evidence	Certified, minor gaps	Uncertified but documented controls	No evidence of controls

#	Risk Factor	Score 1 (Low)	Score 2 (Moderate)	Score 3 (High)	Score 4 (Critical)
9	Breach history	No known history	Minor incident, resolved	Moderate incident within 24 months	Major/unresolved incident
10	Retention practices	Clear, minimal, documented	Documented but generous	Vague/undocumented	Indefinite retention with no deletion mechanism
11	Data deletion capability	Automated, verifiable	Manual but verifiable	Manual, unverified	No deletion capability demonstrated
12	Data Principal rights support capability	Vendor supports rights requests via defined SLA	Supports on request, no SLA	Limited/ad hoc support	No support capability
13	Incident notification capability	Contractual SLA <24 hrs	SLA 24–72 hrs	SLA >72 hrs	No contractual notification commitment
14	AI/automated processing involvement	None	Assistive only, human-reviewed	Significant automation, human oversight limited	Fully automated decisioning, no human review

7.3 Risk Calculation Methodology

1. Score each of the 14 factors from 1 to 4.
2. Calculate the **average score** across all factors (sum ÷ 14).
3. Apply the **“highest factor override” rule**: if any single factor scores 4 (Critical), the vendor is provisionally classified Critical regardless of average, pending Privacy/DPO override with documented rationale.
4. Otherwise, classify using the average-score thresholds below.

7.4 Overall Risk Classification Thresholds

Average Score Range	Classification
1.0 – 1.7	Low Risk
1.8 – 2.5	Moderate Risk
2.6 – 3.3	High Risk
3.4 – 4.0 (or any single factor = 4)	Critical Risk

7.5 Mandatory Controls by Risk Level

Risk Level	Mandatory Controls
Low	Standard DPA; annual attestation; Business Owner approval
Moderate	Standard DPA + security questionnaire; Privacy/DPO approval; biennial reassessment
High	Full DPA with audit rights; security architecture review; Privacy/DPO + Information Security approval; annual reassessment; quarterly monitoring check-in
Critical	Full DPA + negotiated indemnity/liability terms; independent security evidence (certification or audit); Senior Management approval; semi-annual reassessment; continuous monitoring; mandatory remediation plan before onboarding

7.6 Escalation Requirements

- Any factor scoring 4 must be escalated to Privacy/DPO and Information Security before proceeding, regardless of overall average.
 - Any Critical classification requires a documented Senior Management decision, minuted and retained in the Governance Register.
 - A vendor that cannot achieve at least “Moderate” on Factor 8 (Security maturity) and Factor 11 (Deletion capability) should not be onboarded without a time-bound remediation commitment attached to the contract.
-

8 . Third-Party Risk Assessment Template

Sample Completed Assessment

Field	Entry
Assessment ID	TPRA-2026-014
Vendor	VerifiTrust Screening (fictional)
Business Owner	Talent Acquisition Lead
Processing Purpose	Employment background verification for job candidates (education, employment history, criminal record, address verification)
Data Involved	Full name, DOB, government ID numbers, address history, employment/ education records, criminal-record search results
Assessment Date	12 February 2026 (fictional)
Assessor	Privacy/DPO Analyst

Risk Questionnaire Scoring

#	Risk Factor	Score	Justification
1	Nature of personal data	4	Includes criminal-record search results and government ID numbers — highest-sensitivity category in this Framework’s internal classification
2	Volume of data	2	Approx. 3,500 candidate verifications per year
3	Scale of Data Principals affected	3	Candidates across all client accounts using the verification add-on
4	Processing purpose sensitivity	3	Verification results influence hiring decisions, though a human recruiter makes the final call
5	Data accessibility	2	Defined verification team with role-based access, per vendor’s disclosure

#	Risk Factor	Score	Justification
6	Hosting/processing geography	1	India-only hosting confirmed
7	Use of sub-processors	3	Uses regional field-verification agents as sub-processors; disclosed but not individually pre-approved by Vintara
8	Security maturity	2	ISO 27001 certified; minor gaps noted in encryption-at-rest evidence for archived files
9	Breach history	1	No known history in past 24 months
10	Retention practices	3	Vendor's default retention (5 years) exceeds Vintara's intended retention window; not yet aligned
11	Data deletion capability	2	Manual deletion process, verifiable via written confirmation
12	Data Principal rights support	2	Supports access/correction requests on request, no formal SLA
13	Incident notification capability	2	Contractual commitment of 48-hour notification (proposed)
14	AI/automated processing involvement	1	No automated decisioning; all results manually compiled and reviewed

Calculation: Sum = 31; Average = $31 \div 14 = 2.21$ → would fall in “Moderate” by average alone. **However, Factor 1 scores 4 (Critical),** triggering the highest-factor-override rule.

Risk Classification: CRITICAL (via override), pending Privacy/DPO review of override justification.

Reasoning Behind the Override Decision: Although most factors score Low–Moderate, the combination of criminal-record data, government ID numbers, and undisclosed-individually sub-processor field agents represents materially higher impact if compromised or misused (potential for identity misuse and reputational/legal harm to candidates from inaccurate criminal-record data). The Framework’s design intentionally does not allow a single high-sensitivity data factor to be “averaged away” by otherwise good vendor hygiene.

Field	Entry
Existing Controls	ISO 27001 certification; role-based access; written confirmation-based deletion process
Required Remediation	(1) Align contractual retention period to Vintara’s 2-year post-hiring-decision window; (2) Require vendor to list and pre-clear named sub-processor field agencies; (3) Formalise 48-hour breach notification SLA in DPA; (4) Obtain encryption-at-rest evidence for archived verification files
Control Owner	Vendor Management Lead, with Privacy/DPO oversight
Target Completion Date	30 April 2026 (fictional)
Residual Risk (post-remediation, projected)	High (downgraded from Critical, pending verification of completed remediation)
Approval Decision	Approved to onboard with conditions — Senior Management sign-off obtained; remediation items tracked as binding contract schedule items with completion deadlines

9 . Vendor Risk Classification Matrix

	LOW RISK	MODERATE RISK	HIGH RISK	CRITICAL RISK
Risk Profile	Minimal personal data, low sensitivity, low volume	Some employment/contact data, moderate volume	Financial, ID, or decision-influencing data; cross-border elements	Highest-sensitivity data (e.g., background-check/criminal-record data), broad access, or unresolved control gaps
Example Vendors	Office-supplies vendor with employee shipping addresses	MailBridge Cloud (email), SupportDeck (helpdesk)	CloudNova Infra (hosting), PayAssure Solutions (payroll), MetricPulse Analytics	VerifiTrust Screening (background verification)
Approval Authority	Business Owner	Privacy/DPO	Privacy/DPO + Information Security (joint)	Senior Management (with Privacy/DPO and Information Security recommendation)
Contract Requirements	Standard DPA clauses	Standard DPA + security schedule	Full DPA + audit rights + defined breach SLA	Full DPA + audit rights + indemnity terms + remediation schedule as binding annex
Security Review Frequency	At onboarding only	Every 2 years	Annual	Semi-annual
Privacy Review Frequency	At onboarding only	Every 2 years	Annual	Semi-annual
Monitoring Requirements	Annual attestation email	Annual attestation + certification check	Quarterly check-in + certification/news monitoring	Continuous monitoring + quarterly formal review meeting
Reassessment Triggers	Contract renewal	Contract renewal, reported incident	Contract renewal, sub-processor change, incident, purpose change	Any change in data volume, sub-processors, technology (e.g., new AI feature), ownership, or any incident

10

. Data Processing and Data Sharing Contract Template (Data Processing Addendum)

VINTARA HR CLOUD — DATA PROCESSING ADDENDUM (DPA) *(fictional governance template — not legal advice; requires legal review before use)*

Preamble note: This DPA is drafted with reference to the DPDP Act’s Data Fiduciary/Data Processor model rather than adapted from GDPR Article 28. Clauses are labelled by nature: **[Statutory-Anchored]** (directly reflects a DPDP Act/Rules obligation), **[Contractual Risk Allocation]** (commercial/legal risk-sharing term not itself required by statute), or **[Governance Best Practice]** (recommended control beyond the statutory floor).

Clause	Summary Text	Label	Governance Rationale
1. Purpose and Scope of Processing	Processor shall process personal data only for the purposes and in the manner described in Schedule A, and for no other purpose.	[Statutory-Anchored]	Reflects Section 8(2)’s requirement of engagement “under a valid contract,” and supports purpose-limitation traceability
2. Processing Instructions	Processor shall process personal data only on documented instructions from Vintara, including with regard to cross-border transfers.	[Contractual Risk Allocation]	Creates a clear instruction trail that supports Vintara’s accountability if a regulator asks who authorised a given processing activity
3. Categories of Personal Data & Data Principals	Schedule A lists the specific data fields and Data Principal categories in scope.	[Governance Best Practice]	Prevents “scope creep” — the Processor cannot claim broader data was implicitly authorised

Clause	Summary Text	Label	Governance Rationale
4. Confidentiality	Processor shall ensure personnel handling personal data are bound by confidentiality obligations.	[Governance Best Practice]	Standard control; not separately mandated by name in the Act, but supports the reasonable-security-safeguards obligation
5. Access Controls	Processor shall implement role-based access limiting personal data access to personnel who need it for the stated purpose.	[Statutory-Anchored]	Operationalises Section 8(5) and Rule 6 security-safeguard expectations
6. Reasonable Security Safeguards	Processor shall implement security measures (encryption in transit/at rest, access logging, vulnerability management) consistent with Rule 6 of the DPDP Rules, 2025, and shall provide evidence on request.	[Statutory-Anchored]	Directly supports Vintara's non-delegable Section 8(5) obligation
7. Use of Sub-Processors	Processor shall not engage a sub-processor without prior written disclosure to, and (for High/Critical-tier vendors) approval of, Vintara, and shall flow down equivalent obligations to any approved sub-processor.	[Contractual Risk Allocation]	The Act does not explicitly regulate sub-processing; this clause is a deliberate contractual control to preserve visibility down the chain

Clause	Summary Text	Label	Governance Rationale
8. Personal Data Breach Notification and Cooperation	Processor shall notify Vintara of any suspected or confirmed personal data breach within a contractually fixed window (recommended: no later than 24–48 hours of becoming aware, tier-dependent) and cooperate fully with Vintara’s own Section 8(6) obligations.	[Statutory-Anchored, with Contractual timeline]	The statutory obligation to notify the Board/ Data Principals sits with Vintara; this clause is how Vintara gets the operational visibility to comply. The specific hour figure is a contractual SLA, not a cited statutory deadline
9. Assistance with Data Principal Requests	Processor shall provide reasonable assistance to enable Vintara to respond to Data Principal rights requests (e.g., access, correction, erasure) within Vintara’s own required timeframes.	[Statutory-Anchored]	Supports Vintara’s obligations toward Data Principals which cannot be discharged without Processor cooperation
10. Retention	Processor shall retain personal data only for the period specified in Schedule A, absent a documented legal retention requirement.	[Statutory-Anchored]	Reflects Section 8(7) erasure obligations flowing down to Processors
11. Data Deletion / Return	On expiry or termination, Processor shall, at Vintara’s election, return or securely delete all personal data (including backups, subject to technical backup-cycle limitations) and certify deletion in writing.	[Statutory-Anchored]	Directly reflects Section 8(7)(b) — Data Fiduciary must “cause its Data Processor to erase” data made available to it

Clause	Summary Text	Label	Governance Rationale
12. Audit and Assurance Rights	Vintara (or an appointed auditor) may audit Processor's compliance with this DPA, or request equivalent third-party certification evidence, on reasonable notice.	[Contractual Risk Allocation]	Not a named statutory clause, but a practical mechanism for Vintara to evidence its own diligence to a regulator
13. Regulatory Cooperation	Processor shall reasonably cooperate with Vintara in responding to inquiries from the Data Protection Board of India or other competent authority relating to the processing under this DPA.	[Governance Best Practice]	Supports timely, coordinated regulatory response
14. Cross-Border Processing Restrictions	Processor shall not process or store personal data in, or transfer it to, a jurisdiction restricted by Central Government notification under Section 16, and shall disclose all processing locations in Schedule A.	[Statutory-Anchored]	Reflects the Section 16 transfer-restriction mechanism (a negative-list model, distinct from GDPR's SCC/adequacy regime)
15. Termination Obligations	On termination, Processor shall cease processing (except as necessary to complete deletion/return obligations) and support an orderly transition.	[Contractual Risk Allocation]	Prevents "processing in limbo" after the commercial relationship ends
16. Evidence of Deletion	Processor shall issue Vintara a signed Data Deletion Confirmation Certificate (Section 13 template) upon completion of deletion obligations.	[Governance Best Practice]	Converts a promise into documented, auditable evidence

Clause	Summary Text	Label	Governance Rationale
17. Liability / Escalation Placeholder	[Reserved for negotiated liability caps, indemnity, and insurance requirements — subject to Legal review; not populated in this governance template.]	[Contractual Risk Allocation]	Genuine legal risk-allocation terms require qualified legal counsel and commercial negotiation; this Framework only flags where such terms belong

--

11 . Data Sharing Approval Matrix / RACI

R = Responsible, A = Accountable, C = Consulted, I = Informed

Activity	Business Owner	Procurement	Legal	Privacy/ DPO	Info Security	IT	Vendor Mgmt	Senior Mgmt
New vendor request	R/A	C	I	C	I	I	C	I
Data sharing assessment (Request Form)	R	I	I	A	I	I	C	I
Privacy risk assessment	C	I	I	R/A	C	I	C	I
Security assessment	I	I	I	C	R/A	C	I	I
Contract review (DPA)	C	R	R/A	C	C	I	R	I

Activity	Business Owner	Procurement	Legal	Privacy/ DPO	Info Security	IT	Vendor Mgmt	Senior Mgmt
High/ Critical-tier approval	C	I	C	R	C	I	C	A
Vendor onboarding	C	I	I	C	R	R/A	R	I
Annual reassessment	I	I	I	R/A	C	I	C	I
Breach response (vendor-originated)	I	I	C	R/A	R	C	C	A (for Board/DP notification)
Vendor termination	R	C	C	C	I	C	R/A	I
Data deletion verification	I	I	I	R/A	C	R	C	I

12 . Third-Party Breach Escalation Process

Stage	Roles Involved	Timeline (Contractual, unless marked Statutory)	Required Evidence	Decision Points	Documentation
Vendor Detects Incident	Vendor security/ops team	Immediate, at point of vendor detection	Vendor internal detection log	—	Vendor incident ticket
Vendor Notifies Organisati on	Vendor → Vintara Vendor Management/ Privacy	Contractual SLA — recommended 24–48 hrs depending on risk tier (see Section 10, Clause 8); <i>not a cited statutory figure</i>	Vendor notification (written)	Is this plausibly a personal data breach?	Notification received log
Initial Incident Triage	Privacy/DPO + Information Security	Within 4 hours of receipt (internal target)	Preliminary facts: data types, volume, cause	Escalate to full assessment?	Triage notes
Privacy and Security Assessmen t	Privacy/DPO + Information Security	Within 24–48 hours of triage (internal target)	Forensic/technical findings, affected data categories and approximate Data Principal count	Confirmed personal data breach?	Assessment report
Personal Data Breach Determina tion	Privacy/DPO (with Legal input)	Upon assessment completion	Determination memo	Yes/No — proceed to impact assessment	Determination record

Stage	Roles Involved	Timeline (Contractual, unless marked Statutory)	Required Evidence	Decision Points	Documentation
Impact Assessment	Privacy/DPO + Information Security + Legal	Immediately following determination	Risk-to-Data-Principal analysis	Severity classification	Impact assessment report
Internal Escalation	Privacy/DPO → Senior Management	Immediately upon confirmed breach	Escalation memo	Senior Management briefed and engaged	Escalation log
DPDP Act Notification Assessment	Legal + Privacy/DPO	As soon as practicable	Legal analysis against then-current DPDP Rules/Board guidance	Statutory — whether/how to notify Data Protection Board and affected Data Principals per Section 8(6), in the prescribed form and manner then in force	Legal notification-assessment memo
Data Protection Board / Data Principal Notification Actions, as legally required	Senior Management + Legal + Privacy/DPO	Per applicable Rules/Board directions at the time of the incident — this Framework does not fix a specific statutory hour-count, and it should be confirmed against the Rules/Board guidance in force when an actual incident occurs	Notification filings/ records	Approved by Senior Management before submission	Filed notifications, correspondence

Stage	Roles Involved	Timeline (Contractual, unless marked Statutory)	Required Evidence	Decision Points	Documentation
Remediation	Information Security + Vendor	Per severity-based target (Critical: immediate; High: <7 days; others: agreed plan)	Remediation plan, evidence of fixes	Remediation verified as complete	Remediation completion report
Root Cause Analysis	Information Security + Privacy/DPO + Vendor	Within 30 days of closure	RCA report	Root cause and contributing factors identified	RCA document
Vendor Corrective Action Plan	Vendor Management + Vendor	Agreed with vendor, tracked to completion	CAP with owners and dates	CAP accepted and tracked	Signed CAP
Closure and Lessons Learned	Privacy/DPO + Information Security + Vendor Management	Within 45 days of incident closure	Lessons-learned summary	Incident formally closed	Closure report, register update

13 . Vendor Offboarding and Data Deletion Checklist

- ◆ Processing termination confirmed in writing by the vendor
- ◆ All user/system access revoked (application, VPN, shared drives)
- ◆ API keys, credentials, and service accounts rotated/removed
- ◆ Data return completed (if return, rather than deletion, was elected) and received/verified by Vintara
- ◆ Data deletion executed by the vendor across production systems
- ◆ Backup data handling addressed — either included in the deletion cycle or a documented backup-expiry schedule confirmed
- ◆ Sub-processor deletion confirmed (vendor obtains and forwards evidence from its own sub-processors)
- ◆ Signed Data Deletion Confirmation Certificate obtained
- ◆ System integrations (SSO, data feeds, web hooks) decommissioned
- ◆ Outstanding/open incidents involving this vendor have been reviewed and closed or transitioned
- ◆ Contractual post-termination obligations reviewed for completion (confidentiality survival, residual data handling)
- ◆ Final privacy sign-off recorded in Governance Register

Data Deletion Confirmation Certificate (Template)

DATA DELETION CONFIRMATION CERTIFICATE *(fictional template)*

Vendor Name: _____ Vintara Contract/DPA Reference: _____ Categories of Personal Data Covered: _____
Deletion Method Used: _____ Systems/Environments Covered (production, backups, archives, sub-processor systems): _____ Date Deletion Completed: _____ Sub-Processor Deletion Confirmed: ☐ Yes ☐ No ☐ Not Applicable Authorised Vendor Signatory (Name, Title, Signature, Date): _____
Received and Verified by Vintara (Name, Title, Signature, Date): _____

14 . Ongoing Vendor Monitoring Framework

14.1 Monitoring Activities

- Annual (or tier-appropriate) privacy reassessment using the Section 7 methodology
- Security certification review (e.g., confirming ISO 27001/SOC 2 renewal)
- Continuous breach/adverse news monitoring for High/Critical vendors
- Contract renewal review — confirm DPA clauses remain current
- Sub-processor change review — any new/changed sub-processor triggers reassessment
- Processing-purpose change review — any expansion of use triggers a fresh Request Form
- Data volume change review — material increases may shift risk tier
- New technology/AI use review — e.g., a vendor adding automated decisioning
- Regulatory change review — tracking DPDP Rules amendments/Board guidance
- Material vendor control change review — e.g., change of hosting provider, ownership, or key security personnel

14.2 Monitoring Calendar by Risk Tier

Risk Tier	Reassessment Frequency	Certification Check	Monitoring Check-in	Continuous Monitoring
Low	At renewal	At renewal	Annual attestation	No
Moderate	Every 2 years	Every 2 years	Annual	No
High	Annual	Annual	Quarterly	Adverse-news monitoring
Critical	Semi-annual	Semi-annual	Quarterly formal review	Continuous adverse-news + breach monitoring

15 . Governance KPIs and KRIs

Metric	Definition	Formula	Target/ Threshold	Reporting Frequency	Owner	Escalation Trigger
% Vendors assessed before onboarding	Share of new data-sharing vendors with a completed Risk Assessment prior to go-live	$(\text{Vendors assessed pre-onboarding} \div \text{Total new vendors}) \times 100$	100%	Quarterly	Privacy/DPO	Any onboarding without assessment
% High-risk vendors with completed remediation	Share of High/Critical vendors whose required remediation items are closed by target date	$(\text{Remediation items closed on time} \div \text{Total remediation items due}) \times 100$	≥90%	Quarterly	Privacy/DPO	<75% for two consecutive quarters
Average privacy review turnaround time	Average days from Request Form submission to Privacy decision	$\text{Sum of turnaround days} \div \text{Number of requests}$	≤10 business days	Quarterly	Privacy/DPO	Average >15 business days
Vendors with overdue reassessments	Count of vendors past their scheduled reassessment date	Count	0	Monthly	Vendor Management	Any Critical-tier vendor overdue

Metric	Definition	Formula	Target/ Threshold	Reporting Frequency	Owner	Escalation Trigger
Vendors without verified deletion processes	Count of active vendors lacking a demonstrated/verified deletion capability	Count	0	Quarterly	Privacy/DPO	Any High/Critical vendor without verified process
Third-party personal data breaches	Count of confirmed personal data breaches originating	Count	Trend monitored (no fixed numeric target)	Per incident + Quarterly summary	Privacy/DPO	Any single Critical-severity breach
Average vendor breach notification time	Average time from vendor's own detection to notifying	Sum of notification times ÷ Number of incidents	Within contractual SLA	Per incident + Quarterly summary	Privacy/DPO	Any instance exceeding contractual SLA
Vendors using unapproved sub-processors	Count of instances where a sub-processor was used without required disclosure/approval	Count	0	Quarterly	Vendor Management	Any instance identified

Metric	Definition	Formula	Target/ Threshold	Reporting Frequency	Owner	Escalation Trigger
Contracts missing mandatory privacy clauses	Count of active vendor contracts lacking one or more mandatory DPA clauses	Count	0	Semi-annual contract audit	Legal	Any Critical-tier vendor found non-compliant

16 . Sample Data Sharing Governance Register

Vendor ID	Vendor Name	Service	Business Owner	Data Shared	Data Principal Category	Purpose	Risk Rating	Contract Status	Security Assessment Status	Privacy Assessment Date	Next Review Date	Sub-Processor Status	Hosting Location	Retention Period	Deletion Verification Status
V-001	CloudNova Infra (fictional)	Cloud hosting	Head of Engineering	Full HCM dataset	All categories	Application hosting	High	Executed	Complete	15-Jan-2026	15-Jan-2027	Disclosed & approved	India (primary), Singapore	Duration of contract + 90 days	Not applicable (active)
V-002	PayAssure Solutions (fictional)	Payroll processing	Payroll Manager	Bank details, PAN, salary data	Client employees	Payroll & statutory filing	High	Executed	Complete	22-Jan-2026	22-Jan-2027	None	India	Per statutory tax-record retention	Not applicable (active)
V-003	VerifiTrust Screening (fictional)	Background verification	Talent Acquisition Lead	ID numbers, criminal-record results, address history	Job candidates	Employment screening	Critical	Executed (with remediation annex)	In progress	12-Feb-2026	12-Aug-2026	Disclosed, pending approval	India	2 years post-hiring decision	Not applicable (active)
V-004	MailBridge Cloud (fictional)	Corporate email/calendar	IT Director	Employee email/metadata	Vintara employees	Communication	Moderate	Executed (standard SaaS terms + DPA rider)	Complete	03-Mar-2026	03-Mar-2028	Global (vendor's own network)	Multi-region (global)	Per mailbox retention policy (3 years)	Not applicable (active)
V-005	MetricPulse Analytics (fictional)	Product usage analytics	Head of Product	Pseudonymised usage/device data	Client HR admins & employees	Product analytics	High	Executed	Complete	18-Mar-2026	18-Mar-2027	Disclosed & approved	US, EU	18 months rolling	Not applicable (active)
V-006	SupportDeck (fictional)	Customer support ticketing	Head of Customer Success	Names, emails, ticket attachments	Client HR admins, Vintara employees	Support ticket management	Moderate	Executed	Complete	05-Apr-2026	05-Apr-2028	Disclosed & approved	India, US	2 years from ticket closure	Not applicable (active)
V-007	SignRight (fictional)	E-signature platform	HR Operations Lead	Names, address, signature, ID uploads	Candidates, client employees	Offer letter/contract signing	High	Executed	Complete	27-Apr-2026	27-Apr-2027	None	India	7 years (contractual record-keeping)	Not applicable (active)

Vendor ID	Vendor Name	Service	Business Owner	Data Shared	Data Principal Categor	Purpose	Risk Rating	Contract Status	Security Assessment Status	Privacy Assessment Date	Next Review Date	Sub-Processor Status	Hosting Location	Retention Period	Deletion Verification Status
V-008	SkillMatch AI (fictional)	AI resume screening	Talent Acquisition Lead	Resume content, inferred scores	Job candidates	Automated candidate scoring	High	Executed (with algorithmic-review clause)	In progress	10-May-2026	10-Nov-2026	None	India	1 year post-hiring decision	Not applicable (active)

17 . Key Findings and Governance Recommendations

(Written as if the author of this project has just conducted a privacy governance review.)

17.1 Key Third-Party Data-Sharing Risks Identified

- Undisclosed/unapproved sub-processing** at the background-verification vendor (field verification agents) creates a visibility gap in the highest-sensitivity data flow in the vendor portfolio. *(Critical)*
- Retention misalignment** between vendor defaults (e.g., VerifiTrust’s 5-year default) and Vintara’s intended purpose-based retention window. *(High)*
- No standing DPA in place for several long-standing vendor relationships** that were onboarded before this Framework existed (legacy MSA-only arrangements). *(High)*
- Limited contractual breach-notification SLAs** — several existing contracts lack a fixed vendor-to-Vintara notification window, which constrains Vintara’s ability to meet its own Section 8(6) obligations. *(High)*
- Cross-border hosting** at the analytics and email vendors has not been formally reviewed against Section 16 notification developments on an ongoing basis. *(Medium)*
- AI/automated-processing due diligence is nascent** — the resume-screening add-on was onboarded before a dedicated AI-risk factor existed in the assessment methodology. *(Medium)*
- No formal offboarding record exists for two vendors decommissioned before this Framework**, so historical deletion cannot be independently verified. *(Medium)*

17.2 Governance Gaps

- No centralised Governance Register existed before this project; vendor data sharing was tracked ad hoc by the department.
- No consistent risk-scoring methodology existed before this Framework; vendor approval depended on individual reviewer judgment.
- RACI for high-risk approvals was undocumented, creating single points of failure (one Legal reviewer historically approved contracts without a formal Privacy sign-off).

17.3 Priority Remediation Actions

Short-Term (0–30 days) — Priority: Critical/High * Formalise sub-processor disclosure and approval for VerifiTrust’s field agents; amend DPA accordingly. *(Critical)* * Issue retention-alignment amendments to VerifiTrust and SignRight contracts. *(High)* * Identify and list all legacy MSA-only vendor relationships lacking a DPA; prioritise for remediation. *(High)*

Medium-Term (31–90 days) — Priority: High/Medium * Execute DPA riders adding fixed breach-notification SLAs to all High/Critical-tier vendor contracts. *(High)* * Conduct the first sub-processor-focused review cycle across all vendors using the updated Request Form field. *(Medium)* * Complete the first AI-risk-factor reassessment of SkillMatch AI under the updated methodology. *(Medium)*

Long-Term (90+ days) — Priority: Medium/Low * Build a recurring cross-border-processing review tied to any Central Government Section 16 notifications. *(Medium)* * Reconstruct/attempt to verify historical deletion status for the two pre-framework decommissioned vendors; where verification is not possible, document the gap and residual risk formally. *(Medium)* * Establish the KPI/KRI reporting cadence (Section 15) as a standing quarterly governance agenda item for Senior Management. *(Low)*

18 . Portfolio Case Study Summary

Project: Data Sharing Governance Framework

Problem: Mid-sized HR-technology companies share personal data with a wide range of third parties — cloud infrastructure, payroll processors, background-verification vendors, communication and analytics platforms — but under India’s DPDP Act, the Data Fiduciary cannot delegate away its accountability by outsourcing the processing. Without a structured governance program, third-party data sharing tends to be ad hoc, inconsistently risk-assessed, and poorly documented, leaving the organisation exposed to both

regulatory risk (security-safeguard and breach-notification obligations) and operational risk (undetected sub-processing, unverified deletion, unmanaged breach response).

My Approach: I designed an end-to-end governance methodology that treats every third-party data-sharing relationship as a lifecycle — from business request through risk assessment, contracting, onboarding, ongoing monitoring, incident response, and offboarding — with clearly assigned accountability at each stage. I built a defensible, transparent risk-scoring model (with an explicit “no averaging away high-sensitivity data” override rule), mapped every control back to specific DPDP Act provisions or clearly labelled it as governance best practice, and produced the practical artefacts (forms, templates, matrices, registers, checklists) needed to actually run the program day to day.

Key Deliverables: * DPDP Act legal-to-governance mapping table * Data Sharing Request Form template * Third-Party Privacy Risk Assessment methodology, questionnaire, and completed sample assessment * Vendor Risk Classification Matrix * Data Processing Addendum (DPA) template with clause-level rationale * RACI / Approval Matrix * Breach escalation workflow distinguishing contractual from statutory timelines * Vendor offboarding checklist and Data Deletion Confirmation Certificate * Ongoing monitoring framework and calendar * Governance KPIs/KRIs * Sample Governance Register (8 vendors) * Findings and prioritised remediation roadmap

Skills Demonstrated: DPDP Act interpretation; third-party privacy risk management; privacy governance program design; vendor due diligence; contract control design; quantitative risk assessment; RACI design; breach governance; data lifecycle governance (retention, deletion, offboarding).

Business Impact: The Framework converts third-party data sharing from an inconsistent, department-driven activity into a consistent, auditable, and risk-proportionate program. It gives the organisation: (1) **accountability** — a documented decision trail for every data-sharing relationship; (2) **consistency** — the same risk methodology and approval structure applied regardless of which department initiates a vendor relationship; (3) **risk visibility** — a live register and KPI/KRI set that lets leadership see vendor risk exposure at a glance rather than discovering it during an incident; and (4) **operational compliance** — practical controls (DPA clauses, breach SLAs, deletion certificates) that give the organisation genuine ability to meet its DPDP Act obligations rather than merely asserting that it does.